

Cyber Kill Chain

A complete, beginner-friendly guide to the seven phases of an attack, with every task, question, explanation and answer.

Learning Path: SOC Level 1 / Jr Penetration Tester - Cyber Defence Frameworks

Difficulty: Easy | Topics: Reconnaissance, Weaponisation, Delivery, Exploitation, Installation, C2, Actions on Objectives

Date: October 2026

About this walkthrough

This document walks through every task of the TryHackMe room **Cyber Kill Chain**. It explains each of the seven phases of Lockheed Martin's model, states the exact question the room asks, explains how to reach the answer, and gives the answer itself.

What you will learn

- What the Cyber Kill Chain is and why defenders use it.
- The seven phases an intrusion passes through, in order.
- The vocabulary of each phase: OSINT, obfuscation, malvertising, zero-day, web shell, DNS tunnelling and more.
- How to map a real breach (the 2013 Target attack) onto the kill chain.

Contents

Task 1	Introduction	3
Task 2	Reconnaissance	4
Task 3	Weaponisation	5
Task 4	Delivery	6
Task 5	Exploitation	7
Task 6	Installation	8
Task 7	Command and Control	9
Task 8	Actions on Objectives	10
Task 9	Practice Analysis and Conclusion	11

Before you start

The Cyber Kill Chain is a **theory** room, so there is no machine to deploy except the final static-site activity. The framework was created by Lockheed Martin in 2011 to describe an intrusion as a chain of predictable phases, so that a defender can break the chain early rather than only reacting at the end. All answers are shown for educational purposes - read the phase, then answer the question yourself before checking.

TASK 1

Introduction

The **Cyber Kill Chain** is a framework developed by **Lockheed Martin** in 2011 to describe the anatomy of a cyber attack. It breaks an intrusion down into a chain of phases, each of which the attacker must complete before moving to the next. The value to a defender is obvious: if you can detect and stop an attacker at any one link, the chain breaks and the attack fails. This makes the model especially useful against **ransomware**, security breaches and **Advanced Persistent Threats (APTs)**.

The chain has seven phases, which the rest of the room walks through one by one:

#	Phase	In one line
1	Reconnaissance	Researching and selecting the target
2	Weaponisation	Building the malware / payload
3	Delivery	Transmitting the weapon to the target
4	Exploitation	Triggering the payload against a vulnerability
5	Installation	Establishing a persistent foothold
6	Command and Control	Opening a channel to control the victim
7	Actions on Objectives	Achieving the goal (theft, encryption, disruption)

Q1. How many phases comprise the Cyber Kill Chain?

ANSWER

7

TASK 2

Reconnaissance

Reconnaissance is the research and planning phase. The attacker gathers as much information as possible about the target's infrastructure, employees and technologies so the later phases can be tailored and believable. Good reconnaissance is what turns a generic attack into a targeted one.

Reconnaissance comes in two flavours:

- **Passive reconnaissance** - quietly reading third-party sources such as search engines, social media, WHOIS records and public forums. The target's own systems are never touched, so nothing is logged.
- **Active reconnaissance** - interacting directly with the target, for example port scanning, banner grabbing or social engineering. This can be detected.

OSINT (Open-Source Intelligence) is the practice of gathering intelligence from publicly available sources. A classic technique is **Google Dorking**: using advanced search operators to surface sensitive information and confidential files that were never meant to be public, such as exposed documents, login pages or directory listings.

Email harvesting is the process of collecting email addresses (from websites, forums and data breaches) to build a target list for phishing. Tools such as theHarvester and Hunter.io automate it, while the OSINT Framework collects many intelligence-gathering tools behind one web interface.

Q1. What is the term for using search engines to reveal sensitive information and confidential files?

ANSWER

Google Dorking

Q2. What type of reconnaissance is it where the attacker checks the social media pages?

ANSWER

Passive Reconnaissance

TASK 3

Weaponisation

Once enough information has been gathered, the attacker moves to **Weaponisation**: creating or acquiring the tools needed to deliver a malicious payload, without engaging the victim yet. Think of it as assembling the weapon and ammunition before firing.

Term	Meaning
Malware	Software designed to damage, disrupt or gain unauthorised access to a computer.
Exploit	Code that takes advantage of a specific system vulnerability.
Payload	The malicious code that actually runs on the target system.

Common weaponisation techniques include embedding malicious **macros** (VBA scripts) in Microsoft Office documents, spreading infected USB drives, using C2 techniques to run commands remotely, and planting backdoors to keep access. Attackers often hide their code with **obfuscation** - deliberately making the code confusing and hard to analyse so that it evades detection and resists reverse engineering.

Q1. What technique is mentioned to evade detection by making it challenging to analyse the malicious code?

ANSWER

Obfuscation

Q2. What built-in feature makes creating a malicious MS Office document possible?

ANSWER

Macro

TASK 4

Delivery

Delivery is how the weapon reaches the target - the method used to transmit the payload or malware. The most common delivery vectors are:

- **Phishing emails** - convincing fake messages that trick the victim into opening an attachment or clicking a link.
- **Infected USB drives** - malware-laden drives left in public places or posted to employees disguised with a company logo.
- **Watering-hole attacks** - compromising a website the target group frequently visits so visitors are redirected to malware via fake pop-ups or drive-by downloads.

Two delivery variants have their own names. **Malvertising** is showing advertisements on legitimate websites that redirect users to malicious pages - because the ads sit on trusted sites, they are easy to trust. **Smishing** is phishing carried out over SMS: a text message with a malicious link or instructions to download malware, exploiting the trust people place in their phone.

Q1. What method involves showing advertisements on legitimate websites to redirect users to malicious pages?

ANSWER

Malvertising

Q2. What phishing attack sends text messages with malicious links or instructions to download malware?

ANSWER

Smishing

TASK 5

Exploitation

Exploitation is the phase where the attacker's code finally executes on the target by leveraging a vulnerability. This might be a malicious macro triggered when a document is opened, a publicly disclosed but unpatched CVE, or a **zero-day exploit** - an exploit used against a vulnerability the vendor does not yet know about, so no patch can exist.

After gaining a foothold the attacker may escalate privileges or move laterally across systems. Defenders look for the signs of exploitation in logs: suspicious command-line arguments, unexpected processes starting, and registry changes or new services being created.

On the defensive side, one control stands out. **MFA (multi-factor authentication)** ensures that even if an attacker has stolen valid login credentials, they still cannot get in without the second factor. This is why credential theft alone is rarely game over on a well-configured system.

Q1. What type of exploit is used before the vendor becomes aware of a vulnerability?

ANSWER

Zero-day exploit

Q2. What technology is mentioned to prevent an attacker from gaining access even with valid login credentials?

ANSWER

MFA (multi-factor authentication)

TASK 6

Installation

In the **Installation** phase the attacker establishes **persistence** - a way back into the system that survives a reboot, a patch, or even being partially detected and removed. Persistence is achieved through several techniques:

- **Web shells** - malicious scripts (ASP, PHP or JSP) dropped onto a web server to keep remote access. Their file types and simplicity make them hard to spot.
- **Backdoors on victim machines** - tools such as Meterpreter (from the Metasploit Framework) give an interactive shell and remote code execution.
- **Modifying Windows services** - using `sc . exe` and `reg` to make malicious payloads run regularly.
- **Registry / Startup folder persistence** - so the payload runs every time the victim logs in.

Attackers also try to cover their tracks. **Timestomping** changes a file's timestamps so it blends in with legitimate files and frustrates forensic analysis. The defensive countermeasure highlighted in this phase is **allowlisting** (application allowlisting): instead of blocking known-bad software, it permits only approved applications to run, so anything unapproved simply cannot execute.

Q1. What tactic allows attackers to execute operating system commands on a target via a web browser interface?

ANSWER

Web shell

Q2. What technique is mentioned to prevent the execution of unauthorised or malicious software by only allowing approved applications to run?

ANSWER

Allowlisting

TASK 7

Command and Control

In the **Command and Control (C2)** phase the attacker establishes a communication channel with the compromised system to control it remotely. The infected machine repeatedly 'phones home' to the attacker's C2 server - a pattern known as **C2 beaconing** - which allows ongoing control of the victim.

Older channels such as IRC are now rarely used because they are easy for security systems to detect. Modern C2 traffic hides inside protocols that networks cannot simply block:

- **HTTP (port 80) and HTTPS (port 443)** - web traffic blends in with normal browsing and slips past firewalls. HTTPS also encrypts the traffic.
- **DNS** - the victim makes frequent DNS requests to a server and domain controlled by the attacker. Hiding data inside these queries is called **DNS tunnelling**. Because DNS is essential to the whole internet, it is hard to block outright.

Q1. What is the name of the tactic where data is hidden within DNS queries?

ANSWER

DNS tunnelling

Q2. What protocol would the attacker use to smuggle his data as encrypted web traffic?

ANSWER

HTTPS

TASK 8

Actions on Objectives

In the final phase the attacker fulfils their goal. Typical actions include:

- Stealing credentials from users to gain further access.
- Privilege escalation - reaching something like domain administrator, often by exploiting misconfigurations.
- Internal reconnaissance to find more vulnerabilities.
- Lateral movement to expand control across the network.
- Collecting and exfiltrating sensitive data such as intellectual property or personal information.
- Deleting backups and **shadow copies** (Microsoft's built-in snapshot technology) to hinder recovery.
- Overwriting or corrupting data to cause further damage.

The term for stealing sensitive files out of a target network is **data exfiltration**. One attack type needs no introduction: **ransomware** encrypts a victim's files and demands payment in exchange for the decryption key. The security principle that limits the damage any single compromise can cause is the **principle of least privilege** - give every user only the access they actually need, so that a stolen account cannot touch everything.

Q1. What is the term for stealing sensitive files from a target network?

ANSWER

Data Exfiltration

Q2. What principle limits who can access sensitive systems and data to minimise damage caused by an attacker?

ANSWER

Principle of least privilege

Q3. What type of attack involves encrypting files and demanding payment in exchange for the decryption key?

ANSWER

Ransomware

TASK 9

Practice Analysis

The 2013 Target breach

This task uses the infamous **Target** data breach of 2013 as a case study. Attackers stole around 40 million credit and debit card records between 27 November and 15 December 2013, and Target ultimately paid an \$18.5 million settlement - at the time the largest data-breach settlement in history. The static site asks you to place each attacker action into the correct kill-chain phase (a drag-and-drop mapping).

Action	Correct phase
Exploit public-facing application	Exploitation
Data from local system	Actions on Objectives (Exfiltration)
PowerShell	Weaponisation
Dynamic linker hijacking	Installation
Spearphishing attachment	Delivery
Fallback channels	Command and Control

Reading the flag

Once every item is placed in the correct phase, the static site reveals the completion flag. (The argument is that client-side activities cannot enforce an answer - and it is a nice reminder that a static site has already handed the browser everything it knows.)

Q1. What is the flag after you complete the static site?

ANSWER

THM{CKC_NJHERDX327}

Limitations of the Cyber Kill Chain

The kill chain is a useful model, but it is not perfect and should not be the only framework you rely on:

- **Outdated framework** - developed in 2011, it has not been meaningfully updated while attacker tactics have evolved, which can leave security gaps.
- **Limited scope** - it was designed to secure the network perimeter against malware, whereas modern adversaries combine many tactics and techniques.
- **Adversaries evolve** - attackers bypass traditional defences by changing file hashes or IP addresses, defeating signature-based detection.

- **Insider threats** - people who already have authorised access do not fit neatly into the model's phases.

For a stronger defence, combine the kill chain with other models such as **MITRE ATT&CK**, which maps adversary behaviour across all stages of an attack, and the **Unified Kill Chain**, which extends the traditional framework and is better suited to modern threats (including insider threats).

Answer key at a glance

Every question in the room, in one place. Try to answer each phase's questions yourself first, then use this table to check your answers.

Task	Question	Answer
1	Number of phases in the Cyber Kill Chain	7
2	Using search engines to reveal sensitive information	Google Dorking
2	Type of recon when checking social media pages	Passive Reconnaissance
3	Making malicious code hard to analyse	Obfuscation
3	Built-in feature enabling malicious Office documents	Macro
4	Ads on legitimate sites redirecting to malicious pages	Malvertising
4	Phishing attack sent over text messages	Smishing
5	Exploit used before the vendor knows of the flaw	Zero-day exploit
5	Technology that blocks access even with valid credentials	MFA
6	Running OS commands via a web browser interface	Web shell
6	Only allowing approved applications to run	Allowlisting
7	Hiding data within DNS queries	DNS tunnelling
7	Protocol used to smuggle data as encrypted web traffic	HTTPS
8	Stealing sensitive files from a target network	Data Exfiltration
8	Principle that limits who can access sensitive data	Principle of least privilege
8	Encrypting files and demanding payment	Ransomware
9	Flag after completing the static site	THM{CKC_NJHERDX327}

Next steps

Move on to the **Unified Kill Chain** room to see how the model is extended for modern, multi-stage attacks, and to **MITRE ATT&CK**; for a catalogue of real-world adversary tactics and techniques. Whenever you analyse an intrusion, try to place what you see onto the seven phases - naming the phase is what turns a pile of alerts into a story.